

G-CAF

GovDigital Composable Architecture Framework

Volume 3

Contracts & Governance

v2.0

Table of Contents

Chapter 1 Contract System Overview

How contracts connect and the Value Contract as glue

Chapter 2 Value Realization Contract

Why does this PBC exist?

Chapter 3 Security Architecture Contract

Security standards for all PBCs

Chapter 4 Data Architecture Contract

Data handling, classification, and quality

Chapter 5 Integration Architecture Contract

API, event, and gateway standards

Chapter 6 NFR Baseline Contract

Availability, performance, scalability, recovery

Chapter 7 Operations Contract

Runtime operational commitments

Chapter 8 Interface Contract Framework

Separating implementation from stable APIs

Chapter 9 Cross-Entity SLA Framework

SLA requirements for shared PBCs

Chapter 10 FinOps & Cost Allocation

Cost transparency for shared capabilities

Chapter 11 Runtime Support RACI

Support responsibilities by operational model

Chapter 12 PBC Lifecycle Gateways

Initiation, Design, Go-Live, and Retirement gates

Chapter 1

Contract System Overview

G-CAF uses a system of **versioned standard contracts** that all PBCs must comply with. Contracts are governed by the ARB (versions) and validated at PBC Gateways.

Contract Hierarchy

The **Value Contract** sits at the top as the connective tissue. It answers "Why does this PBC exist?" and determines how other contracts apply based on business drivers and resolved tensions.

Contract	Module ID	Owner	Scope
Value Realization Contract	G-CAF-076	Value Realization Office	Cross-cutting (Glue)
Security Architecture Contract	G-CAF-070	Cyber Security	Cross-cutting
Data Architecture Contract	G-CAF-071	Data Office	Cross-cutting
Integration Architecture Contract	G-CAF-072	Integration Team	Platform Tier
NFR Baseline Contract	G-CAF-073	EA Office	Cross-cutting
Operations Contract	G-CAF-074d	Platform Operations	Operations Frame
Interface Framework	G-CAF-080	EA Office	Cross-cutting

Supporting Contracts

Contract	Module ID	Purpose
Cross-Entity SLA	G-CAF-074c	SLA requirements for shared PBCs
Runtime Support RACI	G-CAF-074a	Support responsibilities by operational model
FinOps Cost Allocation	G-CAF-074b	Cost transparency for shared capabilities
AI Code Assistant Policy	G-CAF-081	Governance for AI-assisted development

Contract Versioning

All contract versions are tracked in a central version registry. PBCs declare which contract version they comply with. New versions include migration windows. The ARB approves new contract versions.

Chapter 2

Value Realization Contract

The Value Contract is the **connective tissue** of G-CAF. While other contracts define technical compliance, the Value Contract answers: **"Why does this PBC exist?"**

What the Value Contract Does

- **Connects** PBC delivery to business drivers and strategic outcomes
- **Prioritizes** other contract requirements based on value intent
- **Resolves** principle tensions through explicit trade-off decisions
- **Binds** both delivery teams AND the Value Realization Office to mutual commitments
- **Protects** delivery from ad-hoc intervention through defined milestones

Mutual Commitment

Party	Commits To
PBC Owner	Articulate value clearly, track outcomes, report honestly
VRO	Validate upfront, support at milestones, respect boundaries
DDA	Approve trade-offs, enforce milestone discipline

VRO co-signs the Value Frame at Initiation. This creates shared ownership — VRO cannot later criticize what they approved.

Value Frame Structure

Element	Description	Example
Primary Driver	Main business driver this PBC serves	BD-002 Speed to Market
Secondary Drivers	Supporting drivers (max 2)	BD-001 Cost Efficiency
Driver Justification	Why these drivers apply	Enables 50% faster onboarding
Strategic KPI Link	Which strategy KPI this supports	Employee Time Saved: 500K hrs
Tension Resolutions	Explicit trade-off decisions	Speed over vendor independence
VRO Milestones	Agreed value checkpoints	Month 6: pilot metrics

Chapter 3

Security Architecture Contract

Security standard contracts apply to all PBCs. PBCs must declare which contract version they comply with.

Security Principles

Principle	Description
Zero Trust	Verify explicitly; least privilege access; assume breach
Defense in Depth	Multiple layers of security controls
Secure by Default	Default PBC configurations must be secure
Fail Secure	PBC failures must not compromise security

Architecture Principle Alignment

Principle	Contract Implementation
ARC-003 Security by Design	Threat modeling, security architecture
ARC-004 Privacy by Design	Data classification, PII handling
ARC-005 Zero Trust	Zone requirements, authentication
ARC-010 Design for Failure	Fail secure, graceful degradation

Key Requirements

Category	Requirements
Authentication	Centralized IdP integration, MFA for privileged access, RBAC/ABAC
Encryption	TLS 1.3 in transit, encryption at rest, keys in Key Vault
Zero Trust Zones	Identity verification for all access, no network-based implicit trust
DevSecOps	SAST in CI/CD, DAST pre-release, SCA for dependencies, IaC scanning
Public-Facing	WAF, bot protection, DDoS mitigation, UAE Pass integration
Network Security	Segmentation, firewalls, IDS/IPS, DNS security
Third-Party Risk	SaaS SSO onboarding, risk assessment, security assurance

Chapter 4

Data Architecture Contract

Data standard contracts govern how PBCs handle government data — classification, ownership, quality, residency, and sharing.

Data Classification Levels

Classification	Description	Handling Requirements
Open	Public disclosure, no restrictions	No restrictions; proactive publication
Confidential	Day-to-day operational data	Access controls; audit logging
Sensitive	PII, financial records, system configs	Encryption; strong auth; comprehensive audit
Secret	Highly sensitive, multilevel protection	Maximum protection; need-to-know; no external sharing

All unclassified data SHALL be treated as Confidential until classification determines otherwise.

Key Requirements

Category	Requirements
Data Ownership	Single Source of Truth per entity, purpose limitation defined
Data Classification	All data classified, residency compliant, access controls
Data Quality	Quality dimensions measured, improvement tracked
Data Sharing	Sharing method defined (API/Event), no direct DB coupling
Data Sovereignty	UAE data residency, cross-border restrictions
Database Design	Documentation, clustering, HA, indexing, caching
Reporting	Real-time and historical, dashboards, self-service, export formats

Policy Alignment

Policy Principle	Contract Section
DATPOL-001 Data Ownership	Data Ownership (single source of truth)
DATPOL-002 Data Transparency	Data Classification (metadata)
DATPOL-003 Data Quality	Data Quality dimensions
DATPOL-004 Data Access and Privacy	Classification, Residency

Policy Principle	Contract Section
DATPOL-005 Data Sharing	Data Sharing standards
DATPOL-006 Federated Governance	Data Ownership Governance

Chapter 5

Integration Architecture Contract

Integration contracts govern how PBCs communicate via the DGE API Gateway (GovDX). All integrations **MUST** route through the gateway.

API Standards

Standard	Requirement
Style	REST (default); GraphQL (approved cases); gRPC (internal)
Specification	OpenAPI 3.0+ for all PBC APIs
Versioning	URI versioning (v1, v2); semantic versioning
Authentication	OAuth 2.0 / OpenID Connect
Registration	All APIs registered in GovDX
Errors	RFC 7807 Problem Details standard format

DGE API Gateway — Mandatory

Requirement	Description
Mandatory Routing	All API calls MUST traverse DGE API Gateway
No Direct Calls	Direct PBC-to-PBC calls prohibited
Protocol Support	REST, SOAP, GraphQL supported
Data Formats	JSON (default), XML (legacy), CSV (bulk)
Rate Limiting	Default 1000 req/min; configurable per API
Request Validation	Schema validation at gateway level

Event Standards

Standard	Requirement
Format	CloudEvents specification
Schema	JSON Schema for all events
Naming	Standard naming convention enforced
Registration	All events registered in catalog

Standard	Requirement
Idempotency	Event handlers must be idempotent

Schema Evolution Rules

PBC APIs must follow tolerant evolution: accept unknown fields, use additive changes where possible, and provide migration windows for breaking changes. Consumers must implement tolerant readers.

Chapter 6

NFR Baseline Contract

NFR contracts define quality attributes all PBCs must meet, scaled by criticality level.

Availability Standards

Criticality	Availability	Downtime/Year
Critical	99.95%	~4.4 hours
High	99.9%	~8.7 hours
Medium	99.5%	~43 hours
Low	99.0%	~87 hours

Performance Standards

PBC Type	Response Time Target
Interactive APIs	< 500ms (95th percentile)
Real-time APIs	< 100ms
Batch Processing	Defined per PBC

Scalability Requirements

Criticality	Scaling Requirement
Critical	Auto-scale; no manual intervention required
High	Auto-scale with defined thresholds
Medium	Manual scale with playbook
Low	Capacity planning only

Recovery Requirements

Criticality	RTO	RPO
Critical	< 1 hour	< 15 minutes
High	< 4 hours	< 1 hour
Medium	< 24 hours	< 4 hours

Criticality	RTO	RPO
Low	< 72 hours	< 24 hours

Observability Requirements

Requirement	Description
Metrics	Standard metrics exposed (latency, throughput, errors)
Logging	Structured logs with correlation IDs
Tracing	Distributed tracing for cross-PBC calls
Alerting	SLA-based alerts configured
Dashboards	Operational dashboards available

Chapter 7

Operations Contract

The Operations Contract defines **operational commitments** PBCs must fulfill for production readiness. It consolidates requirements from all Operations Frame modules.

Scope

Applies to all PBCs classified as Tier 1 (Mission Critical) or Tier 2 (Business Critical) at Production maturity or higher.

Security Operations Requirements

Requirement	Tier 1	Tier 2	Tier 3
SOC integration	Required	Required	Recommended
SIEM log forwarding	Required	Required	Optional
Incident response runbook	Required	Required	Recommended
Threat detection rules	Required	Recommended	Optional
Security review frequency	Monthly	Quarterly	Annually

Secrets Management

All tiers require Key Vault integration. Tier 1 and 2 require automated secret rotation and access audit logging. Tier 3 requires manual rotation at minimum.

Observability, Capacity & BCM

The Operations Contract requires structured logging with correlation IDs, metrics endpoints, distributed tracing, health endpoints, and alerting — all scaled by criticality tier. Capacity management requires justified resource sizing and auto-scaling for Tier 1/2. Business continuity requires multi-AZ HA, multi-region DR for Tier 1, and defined RTO/RPO for all tiers.

Chapter 8

Interface Contract Framework

Interface Contracts provide a formal separation between PBC internal implementation and the stable external API that consumers depend on.

Key Benefits

- **Independent Evolution** — PBC internals can change without affecting consumers
- **Bounded Change Impact** — Interface changes are explicit and planned
- **Consumer Protection** — Stability guarantees based on PBC Stability Tier
- **Version Transparency** — Consumers depend on specific interface versions

Interface Contract Contents

Component	Description	Format
API Specification	All REST/GraphQL endpoints	OpenAPI 3.0+
Event Schemas	Published events	JSON Schema + CloudEvents
Data Types	Shared data structures	JSON Schema
Error Contracts	Standard error responses	RFC 7807
Consumer Contracts	Expected consumer behaviors	Pact/similar
SLA Declaration	Performance commitments	NFR Contract
Deprecation Schedule	Planned removals with migration path	Timeline

Interface Lifecycle

Draft → **Approved** (DDA) → **Active** (published in GovDX, consumers depend on it) → **Deprecated** (migration window active, removal planned)

Versioning Rules

Change Type	Version Impact	Process
Additive (new optional field)	PATCH or MINOR	Deploy; notify consumers
Compatible (new endpoint)	MINOR	DDA notification
Breaking (field removal, type change)	MAJOR	DDA approval; deprecation window; migration support

Chapter 9

Cross-Entity SLA Framework

Defines SLA requirements for shared PBCs consumed across entity boundaries.

SLA Tier Alignment

Criticality	Availability	Response Time	Throughput
Critical	99.95%	< 200ms (p95)	Per capacity plan
High	99.9%	< 500ms (p95)	Per capacity plan
Medium	99.5%	< 1000ms (p95)	Best effort
Low	99.0%	< 2000ms (p95)	Best effort

SLA Reporting

Report	Frequency	Content
SLA Dashboard	Real-time	Current status and trends
Monthly Report	Monthly	Achievement vs. target, incidents
Quarterly Review	Quarterly	Trends and improvement plans
Annual Assessment	Annual	Strategic SLA adjustments

Breach Escalation

Severity	Criteria	Escalation
Minor	Single month miss < 0.5% below target	Entity notification
Moderate	2 consecutive months miss OR > 0.5% below	DDA review
Severe	3+ consecutive months OR Critical PBC breach	ARB escalation
Chronic	Pattern of repeated breaches	ARB remediation mandate

Chapter 10

FinOps & Cost Allocation

Cost Allocation Model

Cost Category	Allocation Method	Visibility
Shared PBC Development	Proportional to entity benefit (ARB approved)	Annual budget cycle; published rates
Runtime Consumption	Usage-based (API calls, compute, storage)	Monthly dashboard; entity drill-down
Support & Maintenance	Fixed allocation by Operational Model tier	Published in PBC Catalog
Integration (GovDX)	Per-transaction or subscription model	Real-time metering; monthly reconciliation

Cost Transparency Requirements

Rate card publication (annual), consumption dashboards (real-time), monthly reconciliation, forecast capability, and chargeback mechanisms are all required for shared PBCs.

Chapter 11

Runtime Support RACI

Support RACI by Operational Model

Function	Centralized	Federated	Distributed
L1 Support (Triage)	GovDigital (R/A)	Entity (R) / GovDigital (A)	Entity (R/A)
L2 Support (Technical)	GovDigital (R/A)	Entity (R) / GovDigital (C)	Entity (R/A)
L3 Support (Vendor)	GovDigital (R/A)	GovDigital (R/A)	Entity (R) / GovDigital (C)
Incident Management	GovDigital (R/A)	Entity (R) / GovDigital (A)	Entity (R/A)
Capacity Planning	GovDigital (R/A)	Joint (R) / GovDigital (A)	Entity (R/A)
SLA Reporting	GovDigital (R/A)	GovDigital (R/A)	Entity (R) / GovDigital (I)

R=Responsible, A=Accountable, C=Consulted, I=Informed

Support Tiers

Tier	Scope	Typical Resolution
L1 (Triage)	Initial contact, ticket logging, known issues	< 4 hours
L2 (Technical)	Investigation, configuration, workarounds	< 1 business day
L3 (Vendor)	Product defects, patches, vendor escalation	Per vendor SLA

Chapter 12

PBC Lifecycle Gateways

All PBCs must pass mandatory gateway checkpoints throughout their lifecycle. Gateways ensure quality without creating bottlenecks.

Gateway Flow

Initiation → Design → Go-Live → Retirement

Gateway Responsibilities

Gateway	DDA	ARB	Owner
Initiation	Review	Approve (Critical only)	Submit proposal
Design	Approve	Approve (Critical only)	Present architecture
Go-Live	Approve	Inform	Execute deployment
Retirement	Approve	Approve (Critical only)	Execute decommission

Gateway 1: Initiation

Trigger: New PBC proposed (build, buy, or outsource).

Phase	Activities
1. Gather Context	Access PBC Catalog, Technology Standards, Capability Portfolio, Domain Model
2. Assessments	Reuse assessment, business case, sizing validation, vendor evaluation (if Buy)
3. Classify & Decide	Assign Criticality, Sourcing, PBC Type, Stability Tier; approve or reject
4. Register & Trigger	Register PBC as 'Proposed'; trigger ARB (if Critical), procurement (if Buy), Design Gateway

Gateway 2: Design

Trigger: PBC passed Initiation; ready for detailed design.

Phase	Activities
1. Gather Context	Access Architecture Principles, Standard Contracts, Technology Catalog, Reference Architectures
2. Wait for Artifacts	Interface Contract, Security Architecture, Data Model, Domain Model, Technology Spec
3. Review & Validate	Architecture compliance, contract completeness, security, technology choices, anti-patterns
4. Approve & Trigger	Record approval; trigger implementation and Go-Live Gateway

Gateway 3: Go-Live

Trigger: PBC implementation complete; ready for production.

Phase	Activities
1. Gather Evidence	Access approved design, standard contracts, operations contract
2. Wait for Validations	Security validation, NFR tests, GovDX registration, schema registration, observability setup
3. Verify & Decide	Implementation matches design, test results, operational readiness, SLA targets
4. Activate & Trigger	Update Catalog to 'Active'; trigger operations, consumer notification, SLA monitoring

Gateway 4: Retirement

Trigger: PBC planned for retirement.

Phase	Activities
1. Gather Context	Current consumers, stability tier (deprecation window), data retention policies
2. Preparations	Consumer analysis, migration plan, deprecation notice, data archival plan
3. Verify Zero Consumers	Zero API traffic, zero event subscribers, all consumer sign-offs
4. Decide	ARB approval if Foundational tier; verify all pre-conditions
5. Retire & Trigger	Data archival, GovDX removal, catalog update to 'Retired', infrastructure decommission

Department of Government Enablement (DGE) | Abu Dhabi
Enterprise Architecture Office | govdigital.ea@dge.gov.ae